SESSION 05

Bank Branch Security Lab

Phase 5 · Detection: LAPS, audit logging and the Wazuh SIEM · Monday, October 12, 2026

Session goal	Give the branch a way to protect its local admin passwords and to *see* what happens on its machines: unique rotating local admin passwords, detailed audit logging, and a SIEM collecting it all.
Outcome	**Monitoring foundation complete.** Windows LAPS with encrypted AD backup and rotation; a full audit policy on DC01 and BR01-WS01; a Wazuh SIEM on a new Ubuntu server with agents on both machines detecting a real failed logon. One item left open: brute-force detection (Section 5).
Systems built	WAZUH01 (Ubuntu Server 24.04.5, Wazuh 4.14) · Branch01-LAPS-Policy · JRBANKNA-Audit-Policy
Branch network	Unchanged: 10.10.10.0/24 · WAZUH01 static at 10.10.10.20
Skills shown	Windows LAPS, AD schema extension, just-in-time admin rights, advanced audit policy, SIEM deployment on Linux, agent enrollment, log correlation
Next session	Finish brute-force detection (repair Guest Additions on BR01-WS01), then add file integrity monitoring on the Branch01 share.

Executive summary

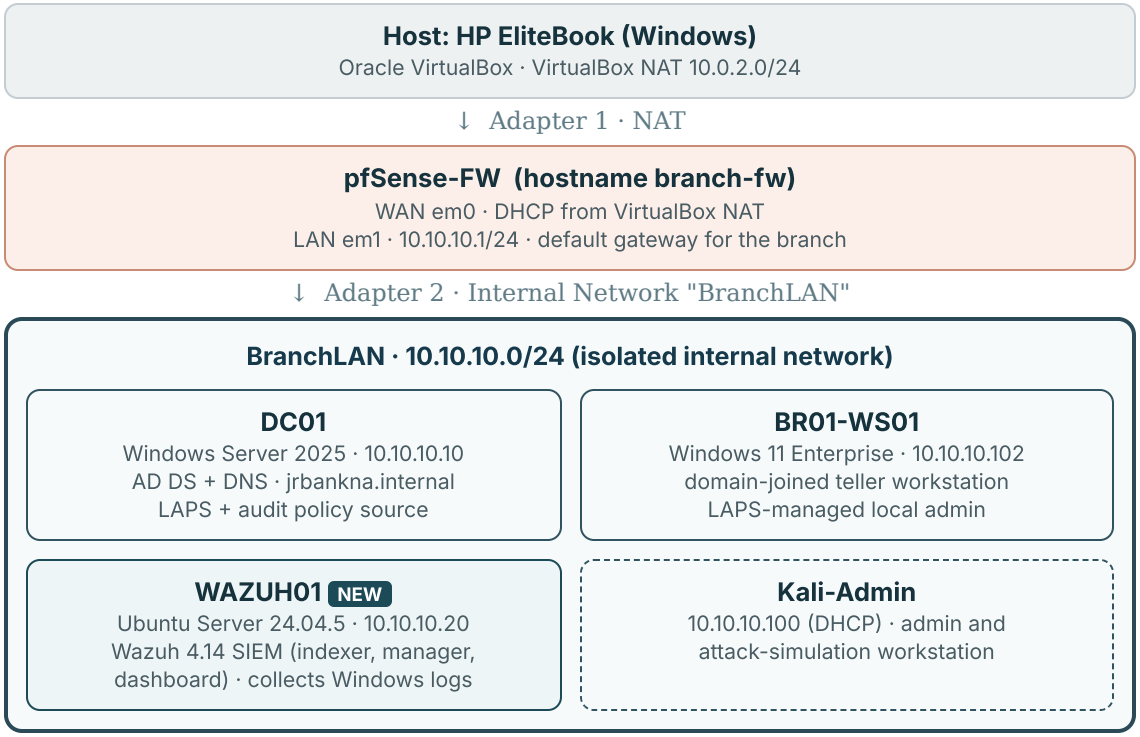
This session added the two things a bank is examined on: protected credentials and an audit trail. I deployed **Windows LAPS**, so every workstation has its own random local Administrator password, stored encrypted in AD and rotated after each use, granting Schema Admins only for the schema change and removing it after. I applied a forest-wide **audit policy** to DC01 and the workstation and proved it by generating a failed logon, a command-line event and an account change, then finding each in the Security log. Finally I built a **Wazuh SIEM** on a new Ubuntu server, enrolled agents on both machines, and watched it alert on a real failed logon within seconds. The brute-force simulation is the one open item, blocked on Windows Server 2025's SMB and a VirtualBox Guest Additions fault to fix next session.

Objectives and status

Objective	Status
Deploy Windows LAPS with encrypted AD backup and rotation	☑ Complete
Extend the AD schema using just-in-time Schema Admins rights	☑ Complete
Apply a detailed audit policy to DC01 and the workstation	☑ Complete
Confirm logging of failed logons, command lines and account changes	☑ Complete
Build the Wazuh SIEM and enroll agents on DC01 and BR01-WS01	☑ Complete
Detect a simulated brute-force attack end to end	☐ To finish (open)

1. Network design

The perimeter is unchanged. **WAZUH01**, a new Ubuntu server in the reserved range, now collects security logs from every Windows machine on the branch LAN. Dashed boxes are still planned.



IP addressing plan (additions this session)

Item	Value	Notes
WAZUH01	10.10.10.20 / 24 (static)	SIEM server; sits in the reserved server range (.2–.99)
WAZUH01 gateway	10.10.10.1	All traffic still crosses the pfSense firewall
WAZUH01 DNS	10.10.10.10	Points at DC01 so it can resolve the domain and reach the internet
Dashboard URL	https://10.10.10.20	Opened from BR01-WS01 on the LAN; self-signed certificate
Reserved for servers	10.10.10.2 – 10.10.10.99	WAZUH01 is the first entry; was planned in Session 02

2. Lab environment

Virtual machine added this session

Setting	WAZUH01
Role	SIEM server: collects, stores and alerts on security logs from DC01 and BR01-WS01
Operating system	Ubuntu Server 24.04.5 LTS (Noble Numbat), 64-bit
Installation media	`ubuntu-24.04.5-live-server-amd64.iso` from releases.ubuntu.com
Memory / CPU	8192 MB RAM · 4 vCPU
Disk	60 GB VDI, dynamically allocated
Adapter 1	Internal Network "BranchLAN" · static 10.10.10.20/24
SIEM software	Wazuh 4.14 all-in-one (indexer + manager + Filebeat + dashboard); repository disabled after install so an `apt upgrade` cannot break it
VM storage	`Documents\lab\vms` alongside the other four VMs

Windows LAPS configuration (Branch01-LAPS-Policy)

Linked to	Branch01 › Workstations OU
Backup directory	Active Directory (encrypted)
Managed account	Built-in local Administrator on each workstation
Password length	15 characters · large + small letters + numbers + specials
Password age	30 days (auto-rotation)
Encryption	Enabled; authorized decryptor is JRBANKNA\Domain Admins only
Post-auth action	Reset the password and log off the account, 8-hour grace period
Schema change	`Update-LapsADSchema`; Schema Admins granted and removed in the same session

Audit policy configuration (JRBANKNA-Audit-Policy)

Linked to	Domain Controllers OU and Branch01 › Workstations OU
Override	Force subcategory settings to override legacy category settings · Enabled
Subcategories	Credential Validation, Kerberos Auth, Logon, Logoff, Account Lockout, Special Logon, User/Computer/Security Group Management, Process Creation, File Share, Directory Service Changes, Audit Policy Change, Sensitive Privilege Use, System Integrity (and others)
Command line	Include command line in process creation events · Enabled
Security log size	196608 KB (192 MB) so events are not overwritten too quickly

3. Work performed

Part A · Windows LAPS

1. **Confirmed the domain functional level** with `(Get-ADDomain).DomainMode`: `Windows2025Domain`, which supports LAPS password encryption.
2. **Located the Workstations OU**: `OU=Workstations,OU=Branch01,DC=jrbankna,DC=internal`.
3. **Granted Schema Admins temporarily** to `adm.jryounger`, signed out and back in so the right took effect.
4. **Extended the AD schema** with `Update-LapsADSchema`, which added the `ms-LAPS-*` attributes forest-wide, then removed the Schema Admins right immediately.
5. **Delegated self-write** on the Workstations OU with `Set-LapsADComputerSelfPermission` so workstations can store their own passwords.
6. **Built Branch01-LAPS-Policy** and set backup to Active Directory, length 15, age 30 days, encryption on, and a post-authentication reset with an 8-hour grace period.
7. **Enabled the built-in Administrator** on BR01-WS01. The first attempt failed because the account had a blank password; running LAPS first gave it a compliant 15-character password, and enabling it then succeeded.
8. **Ran LAPS on the workstation** with `gpupdate /force` and `Invoke-LapsPolicyProcessing`; event **10018** confirmed the password was written to AD.
9. **Retrieved the password** from DC01 with `Get-LapsADPassword`: Source EncryptedPassword, DecryptionStatus Success, authorized decryptor JRBANKNA\Domain Admins.
10. **Forced a rotation** with `Set-LapsADPasswordExpirationTime`; the password changed to a new value, proving the rotate-after-use control.

Part B · Audit policy

11. **Created JRBANKNA-Audit-Policy** and linked it to the Domain Controllers OU and the Workstations OU, after removing a duplicate link left too high on Branch01.
12. **Enabled the subcategory override**, then set twelve advanced audit subcategories (logon, account management, process creation, file share, privilege use and more).
13. **Turned on command-line logging** for process creation and raised the Security log to 192 MB.
14. **Re-enabled six system subcategories** that Windows silently disabled once the GPO set any advanced audit setting.
15. **Verified with** `auditpol /get /category:*` on both DC01 and BR01-WS01.
16. **Proved detection**: a failed logon produced **4625** on the workstation and **4771** on DC01 (same second, clocks in sync); `ipconfig /all` produced **4688** with the full command line; a test account produced **4720** (created) and **4726** (deleted), both attributed to `adm.jryounger`.

Part C · Wazuh SIEM

17. **Freed disk space** on the host after C: filled to 0 bytes, clearing the Downloads folder and temporary files.

18. **Built WAZUH01** (8 GB RAM, 4 vCPU, 60 GB) on BranchLAN with a static 10.10.10.20.
19. **Reinstalled Ubuntu as 24.04.5** after the download defaulted to 26.04, which Wazuh 4.14 does not support.
20. **Installed Wazuh 4.14** with the all-in-one assistant; indexer, manager, Filebeat and dashboard all started, then disabled the Wazuh repo.
21. **Signed in to the dashboard** at `https://10.10.10.20` from BR01-WS01.
22. **Enrolled agents** on BR01-WS01 and DC01; both report **Active** on v4.14.8.
23. **Confirmed detection**: a real failed logon appeared in Threat Hunting at rule level 5, tagged to a MITRE ATT&CK technique, with `targetUserName: wade.wilson` and `subStatus: 0xc000006a`.
24. **Documented the work** in this report.

4. Design decisions and rationale

These are the choices made this session and the reasoning to give in an interview.

Decision	Rationale
LAPS for local admin passwords	Reusing one local Administrator password across every PC lets an attacker who steals it from one machine unlock them all (lateral movement). LAPS gives each machine its own random password.
Encrypted backup to AD	The password is stored encrypted and only Domain Admins can read it, so a read of the directory does not expose it.
Length 15, not 12	The 12-character domain minimum is for people who must memorize passwords. No human types a LAPS password, so a longer one costs nothing and is harder to crack.
Reset after use, 8-hour grace	Once a tech signs in with the LAPS password, it is reset so it cannot be reused. The grace period gives time to finish the fix first.
Just-in-time Schema Admins	Schema Admins can change the blueprint for the whole forest. I granted it only for the schema extension and removed it the same session, limiting the window of risk.
Named admin, not built-in Administrator	Every action is logged under the account that did it. A named account gives non-repudiation; the built-in Administrator is shared and a known attack target, kept as break-glass.
Force subcategory override	Advanced audit subcategories give precise control. The override makes them take priority over the old broad categories so the policy is exact.
Command-line process logging	Attackers live in PowerShell. Recording the full command, not just that a program ran, is what turns a process event into evidence.
192 MB Security log	A busy DC overwrites a small log quickly. A larger log keeps events long enough for the SIEM to collect and for an investigation to find them.
SIEM on supported Ubuntu 24.04	Running a security tool on an unsupported OS is an audit finding. "Deployed on a vendor-supported OS" is the clean interview answer, so I reinstalled off 26.04.
Agent-based collection	An agent on each machine ships logs reliably over the correct protocol, rather than relying on remote pulls that modern Windows SMB blocks.
Snapshot before the attack	Pre-BruteForce snapshots on DC01 and Kali made the attack simulation one click to undo.

5. Troubleshooting log

Incident 1: Win+R kept opening on the host, not the VM

Symptom	Win+R and other Windows-key shortcuts opened on the EliteBook instead of inside DC01. The keyboard-capture arrow turned black on every attempt.
Root cause	VirtualBox released the keyboard the moment the Windows key was pressed; the capture state had come loose, most likely after a sign-out.
Resolution	Re-captured the keyboard, and when that did not hold, restarted the VM window — turn it off and on. Capture then stuck.
Lesson	Isolate the layer first: this was the hypervisor's keyboard capture, not Windows. Commands typed inside the VM never touch the host, which is a reliable fallback.

Incident 2: net user Administrator /active:yes was denied

Symptom	Enabling the built-in Administrator failed: "The password does not meet the password policy requirements."
Root cause	The built-in Administrator had a blank password, which violates the Session 04 domain password policy that also applies to local accounts on domain-joined PCs.
Resolution	Ran LAPS first so the account received a compliant 15-character password, then enabled it. A second attempt in a non-elevated window failed with error 5 until run as administrator.
Lesson	This was my own hardening doing its job. The fix was to satisfy the policy, not weaken it.

Incident 3: audit policy did not apply to DC01

Symptom	`auditpol` still showed defaults on DC01 after a gpupdate.
Root cause	The GPO had not been created at first, then was linked one level too high on Branch01 and duplicated on Workstations, and was never linked to the Domain Controllers OU where DC01 lives.
Resolution	Removed the duplicate Branch01 link and linked the policy to Domain Controllers. `gpresult /r` then listed JRBANKNA-AUDIT-POLICY under Applied Group Policy Objects.
Lesson	A GPO only affects the OU it is linked to. Confirm the link with `gpresult` before assuming the settings are wrong.

Incident 4: Kali tools could not brute-force DC01's SMB

Symptom	crackmapexec, netexec and hydra all fingerprinted DC01 but every authentication attempt returned a NETBIOS timeout or "invalid reply from target."

Root cause	Windows Server 2025 negotiates SMB 3.1.1 with mandatory signing; these Kali tools did not complete the handshake against that build.
Resolution	Switched the attack to run from BR01-WS01, which talks to DC01 over the correct SMB dialect natively. This is also a more realistic "compromised domain PC" scenario.
Lesson	When three different tools fail the same way, suspect the protocol, not the tool. Pick the vantage point that speaks the target's language.

Incident 5: clipboard and Guest Additions on BR01-WS01 (open)

Symptom	Pasting into the workstation stopped working; the optical drive would not surface the Guest Additions disc (`MediaLoaded: False`) despite a correct 50.7 MB ISO.
Root cause	VirtualBox Guest Additions was never installed (`VBoxService` missing). Moving the optical drive from the SATA controller to IDE let Windows see the device, but the disc still would not load its media.
Resolution	Not yet resolved. Next step is a full VirtualBox restart with the ISO freshly attached, carried over to Session 06.
Lesson	Windows 11 in VirtualBox reads an optical disc unreliably from a SATA controller; an IDE optical drive is more dependable. Know when a side-quest is blocking the goal and set it aside.

6. Verification checklist

☑ = verified this session. ☐ = still to confirm; tick it by hand when done.

Check	How to verify	Result
☑ LAPS schema extended	`Update-LapsADSchema`	Pass · ms-LAPS-* attributes added
☑ Schema Admins removed	`whoami /groups`	Pass · right held only for the task
☑ Workstation stored its password	LAPS Operational event 10018	Pass · written to AD
☑ Password readable by Domain Admins	`Get-LapsADPassword`	Pass · Decryption Success
☑ Password rotates on demand	`Set-LapsADPasswordExpirationTime`	Pass · new password issued
☑ Audit policy applied (DC + WS)	`auditpol /get /category:*`	Pass · 12 subcategories set
☑ GPO reaches DC01	`gpresult /r /scope computer`	Pass · listed as applied
☑ Failed logon logged (WS + DC)	Events 4625 and 4771	Pass · same second, wade.wilson
☑ Command line captured	Event 4688 · `ipconfig /all`	Pass · full command recorded
☑ Account changes logged	Events 4720 / 4726	Pass · adm.jryounger attributed
☑ Wazuh services running	Install summary	Pass · indexer, manager, dashboard
☑ Both agents Active	Agents management › Summary	Pass · BR01-WS01, DC01 · v4.14.8
☑ Wazuh alerts on failed logon	Threat Hunting › Events	Pass · level 5, MITRE-tagged
☐ Post-Session05 snapshots (all 5 VMs)	Machine › Take Snapshot	To do after cleanup
☐ Brute-force raises a higher-level alert	Run from BR01-WS01	Open · blocked on Guest Additions
☐ Host C: drive kept clear	File Explorer › This PC	Watch · refilled during the session